Agent基建专题：沙箱与Token治理

Oct 28, 2026 · @Joanna Ann2018

结论： Agent转向长时间、并行、无人值守地运行后，沙箱和token成为决定运行成本、性能和稳定性的两项基建。两者的底座正在商品化，价值上移到按任务做出的调度与治理决策；这些决策需要任务的目标、进度和结果，而这些信息由harness掌握。因此方向是：底座接入现成方案、接口跟随标准，沙箱调度与token治理自主建设，两类费用记入同一本账，以“每个成功任务的总成本”衡量。

核心逻辑

沙箱与token遵循同一条逻辑：负载变了，底座趋同，价值落在按任务的决策上。

1. **前提：运行单位从“一次对话”变为“一个任务”。** 任务持续数分钟到数天，常并行展开，大部分时间在等待模型、审批或外部事件。资源消耗因此按任务累积，闲置和失控成为主要风险。
2. **底座在商品化。** 沙箱的隔离、启动与调用接口，模型的接入、网关与计费数据格式，都已有成熟且趋同的供给，云厂商还在降价并把它们打包进平台。自建底座既难形成差异，也难在价格上竞争。
3. **价值在上移。** 成本与稳定性越来越取决于按任务做出的决策：沙箱何时启动、何时休眠、故障后如何恢复；每一步用哪个模型、带多少上下文、花到多少应当停止。底座和网关只看到单个请求或实例；harness掌握任务的目标、进度和结果，最适合做这些决策。
4. **方向：底座接现成，决策自己做，费用记一本账。** 接口跟随标准，调度与治理自主建设；沙箱、token与工具费用记入同一本账，以“每个成功任务的总成本”衡量，并与交付结果对应。



两项基建的共同逻辑 · 前提、自己做、统一衡量、接现成

从上往下读：负载变化是前提；按任务的决策自己做，并用同一本账衡量；隔离、接口、网关与计费标准接入现成方案。

沙箱：掌握调度，不造底座

沙箱的隔离、启动和接口已经趋同，差异在调度：何时运行、何时休眠、故障后如何恢复、在哪里运行。

现状判断

- **隔离与启动已趋同。** 主流方案用microVM或gVisor隔离，GKE称90%的沙箱分配在200毫秒内完成 (Google Cloud)。普通容器与宿主机共享内核，2025年11月披露的runc漏洞可导致容器逃逸 (CNCF)。
- **接口向E2B收敛。** 阿里云、腾讯云的沙箱兼容E2B SDK，火山引擎提供基于E2B协议的沙箱管理 (阿里云；腾讯云；火山引擎)。OpenAI Agents SDK也支持接入多家沙箱 (Dataconomy)。
- **就绪慢在环境，不在启动。** 拉取代码、安装依赖远慢于虚拟机启动。Anthropic把沙箱移出会话启动的关键路径后，首token延迟p50下降约60% (Anthropic)。
- **成本由闲置决定。** Agent存活期间多数时间在等待。第三方测算中，同一负载按存活时长计费的方案与闲置即休眠的方案相比，月成本相差约一个数量级 (测算)。

四个决策

- **何时运行（性能）：** 按需启动，首个模型响应不等待沙箱；按仓库和岗位预制环境，复用快照与缓存。

- **何时休眠（成本）：** 按等待对象分级：等待模型时停用CPU，等待审批或外部事件时休眠为快照。常驻Agent的经济性取决于能否休眠；短任务的沙箱费用通常远低于模型费用，重点在就绪时间与成功率。
- **故障如何恢复（稳定性）：** 沙箱可丢弃，会话不丢失：会话记录存于沙箱之外，工作区定期快照，故障后重建并恢复，后端可切换。执行层统一兜底：超时清理整组进程、输出写入文件、限制进程数；高频读写不依赖网络文件系统。
- **在哪里运行（可移植与安全）：** 后端可替换，覆盖海外托管、国内云和自托管开源；支持硬件虚拟化时用microVM，否则用gVisor；沙箱随数据部署；出网默认拒绝，凭证经代理注入，不进入沙箱。

举措

举措	主要内容	衡量指标
沙箱编排层	接口对齐E2B，补充休眠、快照、分叉与恢复；按短任务、长任务与常驻、批量三类负载分池	更换后端无需改动harness
就绪工程	按需启动，环境模板与快照，依赖缓存，预热池	首个响应不等沙箱；环境就绪时间
闲置管理	分级休眠，按活跃度超卖，费用按任务计量	每个成功任务的沙箱成本
恢复与兜底	会话外置，工作区快照，后端切换，执行层兜底标准	断点恢复成功率；长任务存活率
隔离与私有化	microVM与gVisor两档，出网与凭证管控，基于开源底座的私有化部署	沙箱内长期凭证为零；私有化交付周期

Token治理：做任务级治理，不做通用网关

Token治理的重点正从控制用量转向管理投入产出；平台各自管控本产品，跨厂商、按任务、对应结果的治理尚无成熟方案。

现状判断

- **支出已成为独立预算科目。** FinOps基金会2026年调查中，98%的受访者在管理AI支出，两年前为31%；FinOps for AI被列为首要优先事项 (FinOps Foundation)。
- **大厂转向“防失控、看产出”。** 微软自2026年7月起为各部门设定token支出上限，员工可查看个人用量，并表示刷token不是优化目标 (TNW)；亚马逊内部指引同样反对刷token，主张以长期结果而非token消耗评价AI价值 (Crypto Briefing)。
- **平台管控各自为政。** Claude企业版已支持组织、分组和个人限额及按人的成本分析 (Claude)，微软、飞书等也提供类似功能，但都只覆盖自家产品，计价单位也不统一。国内还叠加涨价、峰谷计价和限售 (凤凰网)。

- **网关趋同且风险集中。** 2026年3月，开源网关LiteLLM的两个发布版本被植入凭证窃取代码(LiteLLM)；集中保管各厂商密钥的网关已是高价值攻击目标。计费数据已有标准：FOCUS可将token用量映射为通用账单字段 (FOCUS)。

四项判断

- **归属：** 每个token可追溯到人、Agent、任务和项目，跨厂商统一折算为金额；沙箱与工具费用计入同一本账。
- **预算：** 目标是防止失控，而非限制使用。对人设软限额（告警、快速提额、团队共享额度）；对无人值守的Agent设硬上限（单任务预算、步数上限、循环检测、一键停止）。
- **降本：** 主要杠杆在harness：每一步选用的模型、上下文规模、缓存命中、子Agent与重试次数，以及非紧急任务的低谷或批量调度。降本以eval保证质量为前提，否则节省会转化为返工。
- **价值：** 以每个成功任务、每个被采纳交付物的成本衡量，计入人工复核与返工；不以token用量衡量个人或团队。先公开账目，数据可信后再分摊费用。

国内另需治理供给：建立多厂商额度池，在限售或涨价时自动切换，并按数据分级限定可用模型。

举措

举措	主要内容	衡量指标
统一账本	每次调用标注人、Agent、任务、项目；多来源统一计量并折算为金额；按FOCUS导出	可归属到任务的支出占比
分层预算与熔断	组织、团队、个人、Agent、任务五级预算；对人软限额，对Agent硬上限	超支事件数；失控任务的止损时间
自动降本	分步路由，缓存，子Agent与重试上限，低谷与批量调度；以eval守质量	成功率不降前提下的单任务成本
价值报表	单位产出成本，含复核与返工	有ROI报表的客户占比
供给治理（国内）	多厂商额度池，自动切换，按数据分级限定模型	单一厂商限售时的任务成功率

不做

判断标准只有一条：已经商品化、或会把我们锁进单一平台的环节，接入而不自建。

- 不自研虚拟化底座，不建设通用沙箱云与云厂商比拼单价。
- 不定义私有沙箱协议，接口跟随E2B。
- 不做通用LLM网关：治理逻辑自建，执行点接入客户现有网关，或内置于我们的运行时。

- 不做财务系统：账目按FOCUS导出至客户的FinOps工具。

前提与风险

这一方向成立依赖两个前提，主要风险有两项。

- **前提一：** Agent长时、并行、无人值守的运行方式继续扩大。若主要负载仍是短对话，调度与治理的价值有限。
- **前提二：** 企业继续同时使用多家模型和平台。若某一平台通吃，跨厂商治理的空间会收窄。
- **风险一：云厂商打包并免费提供。** 云厂商可能把调度与治理一并纳入平台。应对是守住跨云、跨模型、可私有化，并与其管理后台对接，而非替代。
- **风险二：过度治理抑制使用。** 硬性限额会压制高产出的使用。应对是对人以告警和提额为主，硬上限只用于无人值守的Agent。

与原规划的对应

两项基建不新增举措，而是落在原规划已有的举措中；需要决定的是优先级。

- **沙箱：** 属于《AI at work 2027方向战略》三攻中的“跑得久”，是A1托管运行时的核心部件；隔离与出网管控属于A3；沙箱计量并入C2的“每个成功任务的总成本”。
- **Token治理：** 落在“管得住”与“算得清”的交汇处，对应B3（治理与成本控制）和C2（毛利工程）中的模型路由，依托C1的工作单元计量、A2的eval和A3的身份。
- **待决：** 建议把B3与C2的模型路由合并为一条“token治理”线；是否从P1提为P0，需结合上半年已排的11条举措决定。
- **先内部使用：** 以我们自己的沙箱与token账单作为首个样板。

参考

- 基准文档：AI Agent 2026复盘与2027规划（调研输入）；AI at work 2027方向战略。
- 各节事实的来源见文中链接；数据截至2026年10月28日，厂商数据为其自述。